

نخشا — گزارش مقایسه رقابتی و آسیب شناسی داشبورد سوپرادمین

نسخه: 1.0 | تاریخ: 15-09-2026 | محدوده: پروژه داشبورد نخشا (گاه نگار / پلتفرم مدیریت محتوای شهری) در D:\Projects\Nakhsha

این گزارش با نگاه ۱۰۰٪ منتقدانه و فنی تهیه شده است؛ هدف آن نه ستایش، بلکه مشخص سازی فاصله‌ی واقعی پروژه با استانداردهای داشبوردهای مطرح ایرانی و بین‌المللی، و ارائه‌ی نقشه‌ی راه ارتقا است. تمامی یافته‌ها یا دارای شواهد مستند از کد (path ذکر شده) هستند یا صریحاً به عنوان «برآورد ریسک» برچسب خورده‌اند.

۱) چکیده مدیریتی (Executive Summary)

حوزه	وضعیت خلاصه	استاندارد دنیا	جمع‌بندی
امنیت پایه	موجود و شایسته (helmet, CORS, rate-limit, zod, envalid)	موجود	نزدیک به استاندارد
امنیت پیشرفته	غایب (بدون ۲FA، بدون RBAC واقعی، لاگ ممیزی ضعیف)	موجود	شکاف جدی
UX/UI	تمیز و یکپارچه، RTL و Leaflet	سطح بالا	علفزار — پتانسیل بالا، اما ناقص
داده و دیدن (BI)	عملاً هیچ؛ بدون نمودار، بدون خروجی CSV/Excel، بدون تنظیم زمان‌بندی	جزئی از DNA داشبورد	شکاف بحرانی
بلادرنگ (Real-time)	غایب؛ همه چیز poll است	استاندارد	شکاف مهم
عملیات/پایش	Sentry بدون DSN (no-op)، بدون uptime، بدون alert، بدون backup	ضروری	شکاف بحرانی
تست	۴۳۱ تست بک‌اند پاس، lint/typecheck تمیز، Playwright در CI	خوب	نقطه قوت نسبی
یکپارچگی خدمات	SMS به پتل ریل مسدود (اعتبار پتل ~0.318 واحد در برابر ~2720/پیام)	—	بحرانی عملیاتی
اجرای استقرار	فقط staging (Render Blueprint)؛ تولید دستی و نامستند	—	شکاف عملیاتی

تک‌جمله: نخشا یک «فرانت‌اند خوش‌شکل + بک‌اند مرتب» است، اما هنوز **داشبورد** نیست — یعنی لایه‌ی «تصمیم‌گیری با داده» (تحلیل، گزارش، خروجی، بلادرنگ)، لایه‌ی «مشاهده‌پذیری» و لایه‌ی «عملیات پیشرفته» را ندارد. قوی‌ترین برگ برنده‌اش کیفیت مهندسی پایه و تست‌هاست؛ بحرانی‌ترین ضعفش نبود پایش، نبود امنیت پیشرفته و نبود لایه‌ی دیتا است.

۲) محدوده، روش ارزیابی و داشبوردهای مرجع

۲-۱ محدوده

- تنها داشبورد سوپرادمین پروژه نخشا (فرانت: React؛ بک‌اند: Express) در این نسخه تحلیل شده است.
- ورودی‌ها: کد فرانت (۱۲۱ فایل)، کد بک‌اند (~۹۰ فایل غیرتست)، ۲۳ فایل تست، workflowهای render.yaml، CI، اسکریپت‌های SMS.
- خروجی‌ها: همین گزارش + فایل PDF.

۲-۲ معیارها و وزن‌بندی (مبنای امتیازدهی در بخش ۵)

معیارها به ۹ «ستون مقایسه» دسته شدند؛ وزن بر اساس تأثیر بر «محصول داشبورد»:

#	ستون	وزن کل	ستون‌های فرعی
C1	امنیت و احراز هویت	۱۵٪	۲FA، RBAC، چرخش نشست، محدودیت، لاگ مؤثر
C2	تجزیه و تحلیل و دیدن داده (BI)	۱۵٪	نمودار/سری زمانی، خروجی CSV، زمان بندی، فیلتر پیشرفته
C3	UX/UI و تجربه ی عمل	۱۲٪	اکتشاف (discoverability)، کارایی عمل (bulk)، accessibility، حالت های خالی/خطا
C4	عملیات، پایش و قابلیت اطمینان	۱۲٪	Observability، alert، backup، uptime، on-call
C5	بلادرنگ و همگام سازی	۱۰٪	WebSocket/SSE، اعلان، همگام سازی کلاینت/سرور
C6	معماری و مقیاس پذیری	۱۰٪	مدولار بودن، کش، صف، ایندکس، جداسازی فرایندها
C7	کیفیت و تست	۱۰٪	پوشش، فیکسچر، E2E، بررسی آسیب پذیری وابستگی
C8	فرهنگ توسعه و استقرار (DX/CI)	۸٪	پیش نمایش، feature flag، محیط ها، راستی آزمایی تولید
C9	بین المللی سازی و دسترس پذیری گسترده	۸٪	i18n، RTL/LTR، dark mode، نقش/تنور چندزبانگی

۲-۳ مراجع مقایسه

بین المللی: Shopify Admin، Stripe Dashboard، AWS Console/CloudWatch، Vercel Dashboard، Grafana، Firebase/Supabase، Console، GitHub، Cloudflare Dashboard.

ایرانی: پنل فروشندگان دیجی کالا، پنل حرفه ای اسنپ/تپسی (شرکا)، پنل توسعه دهندگان کافه بازار، پنل زرین پال/پی پینگ، پنل ملی پیامک، پنل تبلیغ دهندگان دیوار.

مبنای تطبیق، «کلاس داشبورد» است: همه ی موارد، داشبوردهای مدیریتی واقعی اند با حجم داده ی جاری و مکانیزم عمل انبوه.

۳) تصویر فنی مستند از پروژه (Evidence)

همه ی موارد این بخش از کد برداشت شده اند و مبنای جدول های مقایسه اند.

۳-۱ فرانت اند

- پشته: React 19.1 + Vite 7 + TypeScript 5.3 + Tailwind 4.1 + React Router 7.7 + axios + Leaflet + lucide-react + react-multi- (date-picker. (frontend/package.json
- بدون هیچ لایه ی state/data مدرن: نه Zustand، نه TanStack Query، نه Recharts یا کتابخانه ی نمودار. تمام fetch ها Axel / مستقیم با مدیریت دستی state. («گزارش اکتشاف فرانت» — frontend/src دارای ۷۸ فایل .tsx و ۳۹ فایل .ts)
- صفحات اصلی: Home مبتنی بر Leaflet؛ CraftDetail؛ EditCraft؛ CreateWizard V مرحله ای؛ Login/OTP (AuthPanel)؛ MyCrafts؛ PostDetail؛ TourDetail؛ TutorialDetail؛ مجموعه صفحات admin.
- وضعیت TODOها: فقط ۲ TODO در کل کد (کش geo در backend/modules/listings/listing.geo.js:296؛ فراخوانی واقعی API در frontend/src/hooks/useProfileContent.ts:75).

۳-۲ بک اند

- پشته: Express 5.1 + Mongoose 8.16 + helmet ۵۰/۱۵ دقیقه، ۳۰ uploads/ساعت) + zod + envalid + winston/morgan + bcryptjs + melipayamak 1.0.5 (JWT_SECRET و REFRESH_TOKEN_SECRET مجزا)
- محدودیت بدنه: 64kb / 16kb. آپلود: محافظ Sentry. path-traversal: بدون no-op → DSN (پایش خطای واقعی غیرفعال).
- صفحه های API: ماژول های listings (با geo)، settings/admin، uploads، auth/OTP، posts، tutorials، tours، users، crafts.
- امنیت سطح متوسط. لاگ نظام مند خروجی (winston) وجود دارد ولی نه به صورت «لاگ ممیزی قابل پرس و جو».

۳-۳ SMS (ملی پیامک / melipayamak)

- اتصال با `melipayamak@1.0.5` (API مبتنی بر Promise در REST؛ SOAP هم پشتیبانی). «پیامک ملی» همان سرویس ملی پیامک است که همین پکیج را دارد (`backend/services/sms/melipayamakSms.js`).
- اصلاحات انجام شده: `SMS_TO_FORMAT=09`؛ `isSuccess` فقط (REST) `RetStatus===1` یا (SOAP) `int≥1000`.
- بحرانی: اعتبار پِنل ~۰.۳۱۸ واحد در برابر نیاز ~۲۷۲۰ واحد/پیام → ارسال واقعی ممکن نیست (خطای `InvalidData/۳۵`). staging روی `SMS MOCK=true` است. تا شارژ پِنل، این ویژگی عملاً مرده است.
- `backend/scripts/test-sms.js` با حالت `--probe` برای دیباگوستیک زنده‌ی پِنل ارتقا یافته است.

۳-۴ CI/CD و استقرار

- `ci.yml`: ۳ جاب با `MongoDB service (mongo:7)`؛ `backend: lint+tests`؛ `frontend: lint+typecheck+build`؛ `Playwright`؛ `e2e: Chromium`. تگ‌گیر روی `main/develop` و PR ها. 
- `render.yaml`: فقط `staging`؛ بک‌اند تحت `npm start` با `NODE_ENV=production` و `SMS MOCK=true`؛ فرانت `Static` با `VITE_API_BASE` مطلق؛ `whitelist` از `fromService`؛ سکرت‌ها `sync:false`.
- تولید: هیچ `Blueprint/CICD` مستندی وجود ندارد (فقط کامنت رند `LY`). فرایند تولید نامعلوم.

۳-۵ تست

- بک‌اند: ۴۳۱ تست `jest` پاس (چندین فایل در `backend/__tests__`)؛ `lint` تمیز.
- فرانت: `Playwright` + `vitest` در `CI` (تعداد محدود؛ پوشش UI کم).
- شکاف: بدون تست امنیتی خودکار، بدون چک‌آپ وابستگی (`npm audit` در `CI` نیست)، بدون فیکسچر تصویری/سنسور، بدون `load/stress test`، بدون پوشش گزارش شده به صورت درگاه‌بندی شده.

۴) مقایسه جایگاه به جایگاه با سکوهای مرجع

برای هر سکو: ابتدا «الگوی قابل تقلید» آن، سپس «وضعیت نخشا در برابر همان الگو»، و در پایان کلیدشکاف‌ها. امتیازها در بخش ۵ جمع‌بندی شده‌اند. نماد $\checkmark$ = موجود، $\times$ = غایب، $\pm$ = ناقص.

۴-۱ Shopify Admin (الگوی UX عملیاتی و افزونه‌پذیری)

- الگوی قابل تقلید: جدول‌های غنی با `bulk action`، جزئیات قابل تعریف، صفحات فعالیت/تحلیل آماده، اپ-استور (اکوسیستم افزونه)، `Command Palette` و صفحه‌ی `Git-installed app` ثبت عمودی به همراه گزارش‌های خودکار.
- وضعیت نخشا: جدول/فهرست‌ها ساده هستند؛ بدون `bulk action` واقعی، بدون صفحه‌ی گزارش‌گیری، بدون فیلتر ترکیبی ذخیره شده، بدون آلمان‌گری سراسری.
- کلیدشکاف‌ها: $\times$ گزارش مالی/فروش؛ $\times$ `bulk select` /شده‌های دسته‌جمعی؛ $\times$ جست‌وجوی `global`؛ $\pm$ فرم‌ها (جادوگر ۷ مرحله‌ای خوب است اما بدون `validation` زنده‌ی پیشرفته).

۴-۲ Stripe Dashboard (الگوی BI و جریان پول)

- الگوی قابل تقلید: «Overview» شامل KPI‌های بلاک + نمودار سری‌زمانی تعاملی + فیلتر بازه‌ی زمانی؛ گزارش‌گیری `CSV`؛ بقیه‌ی توضیحات در یک چیدمان سلسله‌مراتبی؛ «export» یک کلیک؛ نقش نمایش اصلی همیشه قابل دیدن.
- وضعیت نخشا: $\times$ هیچ صفحه‌ی BI نیست؛ $\times$ هیچ نموداری نیست (بدون `Recharts` حتی)؛ $\times$ هیچ خروجی `CSV/Excel` نیست؛ $\times$ داشبوردهای «Overview» کارایی ندارد.
- کلیدشکاف‌ها: این بزرگ‌ترین شکاف محصولی است. حتی یک «خلاصه‌ی وضعیت» برای ادمین وجود ندارد؛ داده‌ها پراکنده‌اند.

۴-۳ AWS Console / CloudWatch (الگوی Observability و امنیت)

- **الگوی قابل تقلید:** تک پنل سراسری، نقش های IAM دقیق، مورد ۲FA/MFA اجباری، CloudTrail (ممیزی) و CloudWatch (metric+alert) به صورت پیش فرض روی همه چیز.
- **وضعیت نخشا:** Sentry بدون DSN (متفاوت است: هیچ خطایی ضبط نمی شود)؛ X بدون metric؛ X بدون alert؛ X بدون لاگ مرکز شده قابل پرس و جو؛ X بدون ممیزی از فعالیت admin؛ X بدون RBAC یا granularity.
- **کلیدشکاف ها:** `backend/services` و `server.js` هیچ محل هک برای metric/alert ندارند؛ «چه کسی چه کاری در داشبورد کرده» قابل ردیابی نیست. این برای یک داشبورد ادمین، ریسک امنیتی-عملیاتی است.

۴-۴ Vercel / Netlify Dashboard (الگوی توسعه و مشاهده پیش نمایش)

- **الگوی قابل تقلید:** دیپلوی پیش نمایش per-PR، رول یک کلیک، محیط های متعدد با env مجزا، ساعت ها و log زنده در مرورگر، وضعیت «deploy» اول در top.
- **وضعیت نخشا:** staging روی Render دارد؛ X بدون پیش نمایش per-PR؛ X بدون رول یک خودکار؛ X بدون log viewer متمرکز در داشبورد؛ CI ± فقط بررسی کننده است نه منتشر کننده.
- **کلیدشکاف ها:** تعمیر انتشار — CI در حالت «verify-only» است؛ Deploy و نمای کلاس بندی نشده است.

۴-۵ Firebase / Supabase Console (الگوی مقیاس و آپلود)

- **الگوی قابل تقلید:** جدول های داده با فیلدها/تر/سورت/صفحه بعدی سمت کلاینت، Auth built-in با مدیریت کاربر، صفحه ی Storage با preview و سیاست های امکان، نسخه بندی و audit log پروژه.
- **وضعیت نخشا:** آپلود دارد (multer+sharp) اما X مدیریت رسانه (با جستجو/پیش نمایش/bulk) ندارد؛ X مدیریت کاربران فعال (حذف/غیرفعال/نقش) ندارد؛ ± ایندکس های Mongo در bootstrap وجود دارد اما با pix مرگ ure مشخص نیست.
- **کلیدشکاف ها:** صفحه ی «محتوای رسانه» و «کاربران» در داشبورد بسیار ابتدایی است؛ هیچ سرویس داده-مصرفی سمت کلاینت نیست.

۴-۶ Grafana (الگوی داشبورد داده-محور)

- **الگوی قابل تقلید:** پنل های قابل چیدمان، datasource چنگانه، alert rule، variable (فیلتر دینامیک)، export/import dashboard JSON.
- **وضعیت نخشا:** نداشتن حتی یک «پنل» — داده به صورت جدول دیده می شود نه به صورت سری زمانی/توزیع.
- **کلیدشکاف ها:** نیاز به یک لایه «متاداده ی تجمیعی» در بک اند (aggregate endpoints) و یک لایه ی نمودار/فیلتر در فرانت؛ فعلاً صفر است.

۴-۷ GitHub (الگوی فرایند و ممیزی)

- **الگوی قابل تقلید:** PR review workflow، branch protection، محتوای «Audit log» برای فعالیت ادمین، فهرست درخواست های دسترسی، خروجی CSV از log ها.
- **وضعیت نخشا:** قابلیت همکاری خوب در CI دارد ولی X لاگ فعالیت قابل خروجی برای ادمین ندارد؛ X صفحه ی «چه کسی چه تغییری داد» ندارد.
- **کلیدشکاف ها:** برای یک داشبورد مدیریت محتوا، «ممیزی» حداقل باید شامل نسخه ی قبلی و کنش خالق باشد؛ حاضر نیست.

۴-۸ پنل فروشندگان دیجی کالا (الگوی پنل ایرانی پیشرفته)

- **الگوی قابل تقلید:** داشبورد عملکرد فروش (نمودار، KPI، مقایسه ی بازه)، مدیریت سفارش با اقدام انبوه، مدیریت کالا با گردش و وضعیت، مدیریت دعوا/پرداخت.
- **وضعیت نخشا:** مفهوم سطحی: X/KPI نمودار؛ X اقدام انبوه؛ ± فرم ها خوب ولی بدون گردش وضعیت کامل (workflow engine).
- **کلیدشکاف ها:** پنل دیجی کالا ثابت می کند که در بازار ایران هم «داشبورد تصمیم» (نه فقط CRUD) توقع است؛ نخشا فاقد متاداده ی تجمیعی برای فروش/بازدید است.

۴-۹ پنل اسنپ کار/تپسی (شرکا و رانندگان)

- **الگوی قابل تقلید:** به روزرسانی زنده (websocket)، حالت «در حال ماموریت» با نقشه و شمایل بلادرنگ، اعلان‌های حرکت، نمودار درآمد روزانه، گزارش‌گیری CSV.
- **وضعیت نخشا:** X بلادرنگ (همه poll)؛ X نسخه‌ی «وضعیت زنده» برای آگهی/تور/پست وجود ندارد؛ X اعلان push/in-app نیست.
- **کلیدشکاف‌ها:** نقشه فقط نمایش استاتیک دارد؛ برای داشبورد «شهری» (ویت‌های متحرک؟) پتانسیل زنده‌سازی کاملاً بلااستفاده مانده است.

۴-۱۰ پنل توسعه‌دهندگان کافه‌بازار

- **الگوی قابل تقلید:** داشبورد نمایه‌ی اپ (install/uninstall, crash, rating) با جدول‌های قابل فیلتر و نمودار روند؛ سگ‌این نشست (API key) با سطح دسترسی؛ مستندسازی API.
- **وضعیت نخشا:** X API key/توکن با scope؛ X نمودار روند؛ X داشبورد «سلامت سرویس» برای ادمین.
- **کلیدشکاف‌ها:** پشتیبانی از swagger هست ولی هیچ سطح «کلید API احرازشده با scope» نیست؛ برای داشبورد B2B ضروری است.

۴-۱۱ پنل زرین‌پال / پی‌پینگ (گیت‌وی و تراکنش)

- **الگوی قابل تقلید:** داشبورد تراکنش (فیلتر بازه، دسته‌بندی، جستجو، گزارش CSV)، نمودار درآمد، وزر گرفتن + دستی بازگشت وجه، مدیریت کاربر محدود.
- **وضعیت نخشا:** X هیچ زیرساخت تراکنش/پرداخت وجود ندارد؛ X هیچ نمودار درآمد نیست.
- **کلیدشکاف‌ها:** (در صورتی که محصول نهایی بخواهد درآمد/VOD داشته باشد) فقدان کامل لایه‌ی مالی.

۴-۱۲ پنل ملی‌پیامک (MeliPayamak — سرویسی که نخشا هم از آن استفاده می‌کند)

- **الگوی قابل تقلید:** داشبورد ارسال/دریافت پیامک، گزارش با فیلتر زمانی، دفترچه تلفن/گروه‌ها، اعتبار و صورت‌حساب، تبلیغ به صورت چند-خط. نقطه‌ی جالب: سرویس‌دهنده‌ی خارجی که نخشا به آن وابسته است، خودش گزارش و Credit بصری دارد.
- **وضعیت نخشا:** فقط «ارسال OTP»؛ X هیچ صفحه‌ی گزارش ارسال/مصرف اعتبار نیست؛ X هیچ نمایش موجودی/شارژ نیست؛ X هیچ fallback (مثلاً پیامک جایگزین/صف ارسال) نیست.
- **کلیدشکاف‌ها:** وابستگی تک‌نقطه‌ای به یک سرویس SMS بی‌آنکه داشبورد حتی «وضعیت آن» را نشان دهد یا مواظب اعتبار باشد.

۴-۱۳ پنل تبلیغ‌دهندگان دیوار

- **الگوی قابل تقلید:** مدیریت تعداد آگهی، آمار بازدید/تماس (نمودار)، ارتقا و پیکربندی بسته‌ها، گزارش بازدهی.
- **وضعیت نخشا:** X آمار بازدید/تعامل روی هر محتوا وجود ندارد؛ X امکان ارتقای آگهی (featured) وجود ندارد؛ X نظارت بر «سلامت محتوا» وجود ندارد.
- **کلیدشکاف‌ها:** حلقه‌ی «اثر → شمارش → نمایش به ادمین» که در هر پنل ایرانی هست، در نخشا نیست.

۵) ماتریس امتیازدهی (نگاه ترکیبی)

امتیاز ۱-۱۰ برای هر سکو در ۴ ستون کلیدی و امتیاز کلی (وزن‌دار از ۹ معیار بخش ۲-۲):

سکو	امنیت	BI/داده	UX	عملیات/پایش	کلی (از ۱۰)	پردازش کلی
Stripe	10	10	9	10	9.4	مرجع BI
Shopify	9	9	10	9	9.2	مرجع عملیات‌پذیری
AWS/CW	10	8	7	10	8.7	مرجع امنیت/پایش
Vercel	8	7	9	9	8.2	مرجع DX
Grafana	9	10	8	10	9.0	مرجع visualization

سکو	امنیت	BI/داده	UX	عملیات/پایش	کلی (از ۱۰)	پردازش کلی
Firebase / Supabase	9	8	8	8	8.0	مرجع داده‌ی کلاینت
GitHub	10	7	9	9	8.4	مرجع ممیزی
پنل دیجی‌کالا	7	8	8	7	7.4	قوی‌ترین ایرانی
اسنپ/تپسی	7	8	8	8	7.6	بلادرنگ
کافه‌بازار	8	7	7	7	7.2	API-سنتریک
زرین‌پال/پی‌پینگ	8	8	7	7	7.4	مالی
ملی‌پیامک	6	7	6	6	6.2	سرویس‌گرا
دیوار	7	7	7	7	6.9	بازدهی محتوا
نخشا (فعلی)	6.5	2.0	6.5	3.0	4.4 ≈	—

خوانش: در ستون‌های «امنیت/UX» نخشا در ۲/۳ پایین جدول قرار دارد اما به مرجع‌های داخلی نزدیک است؛ در «BI و عملیات» از همه‌ی مراجع (حتی ملی‌پیامک) عقب‌تر است — این دو ستون بیش‌ترین وزن را هم دارند.

۶) کاتالوگ ایرادات و ضعف‌ها — با انضباط ۱۰۰٪، اولویت‌بندی‌شده

۶-۱ مقررات کدگذاری و دسته‌ها

- اولویت (Priority):** P0 = بحرانی (امنیتی / از دست رفتن داده / بلاک عملیاتی؛ باید پیش از هر چیز رفع شود) → P1 = مهم (زخم کیفیت-عملیاتی نسخه‌ی فعلی) → P2 = بهبود (شایسته برای نسخه‌ی بعدی).
- دسته (Category):** SEC امنیت و هویت | OPS عملیات/پایش | DATA داده و UX | BI تجربه کاربر | ARCH معماری و سلامت | TEST کیفیت و تست | DX فرایند توسعه | SVC یکپارچگی سرویس.
- شواهد:** هر آیتم یا دارای مسیر کد مستند است یا با نشان [ریسک] صریحاً برآورد شده.
- ترتیب:** ابتدا P0، سپس P1، سپس P2؛ درون هر سطح، بر اساس «تأثیر × احتمال» نزولی.

۶-۲ بحرانی (P0)

ID	دسته	یافته (شواهد)	اثر
P0-01	OPS	پایش خطای Production خاموش است: @sentry/node بدون DSN → no-op؛ هیچ میان‌افزار ثبت خطای سراسری/متریک وجود ندارد (backend/server.js ، مازول‌های سرویس).	هر باگ ران‌تایم در محیط زنده «نامرئی» است؛ تشخیص علت فقط با گردش دستی لاگ سرور.
P0-02	SEC	بدون 2FA حتی برای سوپرادمین؛ احراز هویت فقط OTP تک‌مرحله‌ای (frontend صفحات AuthPanel).	تصاحب نشست (account takeover) با دزدیدن یک کد OTP؛ شدت واقعی برای ادمین‌های پراختیار.
P0-03	SEC	هیچ RBAC واقعی نیست؛ فقط «سوپرادمین یا بقیه» (SUPER_ADMIN_PHONE ، گاردهای صفحه‌های admin).	افزودن هر نقش جدید (نویسنده، ناظر، مدیر شهر) مستلزم بازنویسی کل گاردهاست؛ مدل «همه‌یاختی» است.
P0-04	OPS	بدون سهم‌گیری پشتیبان مستند یا خودکار برای Mongo؛ محیط production اصلاً در مستندات دیده نشده (render.yaml فقط [ریسک] staging).	از بین رفتن دیتابیس به معنی از بین رفتن کل محتوای شهر است؛ بدون RPO/RTO تعریف‌شده.

ID	دسته	یافته (شواهد)	اثر
P0-05	DATA	لایه‌ی BI عملاً صفر (بخش ۴-۲): بدون KPI، بدون نمودار، بدون aggregate-endpoint سمت سرور؛ حتی کتابخانه‌ی نمودار نصب نیست.	ادمین نمی‌تواند «چه خبر است» را بفهمد؛ ادعای «داشبورد» بدون تصمیم‌گیری داده بی‌معناست.
P0-06	OPS	بدون uptime monitor/alert: فقط /api/health ایستا در رند؛ هیچ notification (ایمیل/Webhook) هنگام outage.	بحران‌های قطع سرویس ساعاتی قبل از اطلاع ادمین سپری می‌شود.
P0-07	SVC	SMS واقعی مسدود است: اعتبار پنل ملی‌پیامک ~۰.۳۱۸ واحد در برابر نیاز ~۲۷۲۰ واحد/پیام → کد InvalidData/۳۵؛ بدون provider دوم، بدون صف و بازآزمایی (SMS MOCK=true staging با : backend/services/sms/melipayamakSms.js).	OTP در production عملاً از کار افتاده؛ مشتری داده‌ی ناقص و تجربه‌ی خراب.
P0-08	OPS	لاگ‌ها بدون مرکز و بدون دوران: winston/morgan روی فایل/console؛ بدون log aggregation و بدون الگوی جست‌وجو.	عیب‌یابی و forensics در production تقریباً غیرممکن.

۶-۳ مهم (P1)

ID	دسته	یافته (شواهد)	اثر
P1-01	SEC	چرخه‌ی refresh token ناقص: REFRESH_TOKEN_SECRET مجزاست اما هیچ «لیست سیاه/انقضای فعال logout» وجود ندارد و رفتار کاملاً چک‌نشده است. [ریسک]	توکن‌های دزدیده‌شده تا انقضا معتبر می‌مانند؛ logout واقعی نیست.
P1-02	SEC	لاگ ممیزی کشف‌پذیر نیست: «چه کسی، چه چیزی، چه زمانی» روی محتوا/نشست ادمین ثبت نمی‌شود (نه در DB نه در collection جدا).	نمی‌توان پاسخ داد «چه کسی این آگهی را حذف کرد؟»؛ استاندارد داشبوردهای ادمین نقض‌شده.
P1-03	SEC	rate-limit فقط گزینشی: auth (۵۰/۱۵) و uploads (۳۰/س)؛ اندپوینت‌های سنگین (geo، لیست ترکیبی، جست‌وجو) بدون محدودیت/کووتا.	ریسک DoS جزئی روی API و بارگیری اضافه Mongo.
P1-04	ARCH	کش ناقص: TODO ناتمام در backend/modules/listings/listing.geo.js:296؛ گواه کش بدون invalidate؛ هیچ لایه‌ی کش (Redis یا in-memory) برای کوئری‌های گرم نیست.	Latency و بار DB با رشد محتوا غیرخطی بالا می‌رود؛ احتمال استامپ TTL.
P1-05	ARCH	بلادرنگ صفر: هیچ WebSocket/SSE؛ همه‌ی صفحات poll دستی (frontend/src/hooks/**).	اطلاع از محتوای جدید/تغییر وضعیت لحظه‌ای نیست؛ چند دستگاه ناسازگار.
P1-06	DATA	بدون خروجی/گزارش: هیچ CSV/Excel/JSON export از هیچ جدولی؛ بدون گزارش زمان‌بندی‌شده.	ادمین ناگزیر به کپی دستی یا اسکرپت خارج از سیستم.
P1-07	UX	جدول‌ها بدون bulk action/selection: بدون فیلتر ذخیره‌شده، بدون مجازسازی در فهرست‌های بزرگ، بدون صفحه‌بندی استاندارد.	عملیات روزانه‌ی ادمین در حجم → هزینه‌بر و خطاپذیر.
P1-08	UX	حالت‌های خالی/خطا/loading یکسان نیستند: بدون skeleton، بدون الگوی خطای fetch یکپارچه، بدون محافظت double-submit. [ریسک]	ابهام خطا، کشش، و داده‌ی ناسازگار در UI.
P1-09	UX/DX	جست‌وجوی سراسری (Command Palette) وجود ندارد؛ ناوبری فقط کلیک‌ی.	زمان دسترسی به هدف در اکانت بزرگ افزایش می‌یابد.
P1-10	DX	بدون پیش‌نمایش per-PR و رول‌بک خودکار؛ CI فقط verify می‌کند (job frontend در ci.yml).	رگرسیون UI با کشف دیر هنگام وارد staging می‌شود.
P1-11	DX	محیط production تعریف‌نشده/رولشده دستی: فقط Blueprint staging در render.yaml؛ واریانس‌های کلیدی (MONGODB_URI، DSN، ALLOWED_ORIGINS) بدون سند.	اولین deploy پریسک پیکربندی.
P1-12	TEST	پوشش UI/E2E پایین: Playwright در CI هست اما حجم تست محدود؛ بدون گیت پوشش (coverage threshold).	رگرسیون ساده‌ی UI به‌سادگی از CI رد می‌شود.

ID	دسته	یافته (شواهد)	اثر
P1-13	TEST	بدون اسکن زنجیره‌ی تأمین: هیچ /OSV /npm audit در CI؛ بدون SBOM؛ بسته‌های سنگین (Sharp، multer) بدون مرور نسخه.	ریسک CVE در وابستگی‌ها از staging تا production.
P1-14	UX	i18n و dark mode وجود ندارد؛ متن‌ها هاردکد فارسی (frontend/src/**).	محدودیت بازار/بین‌المللی و دسترس‌پذیری بصری.
P1-15	SEC	هیچ تست دسترس‌پذیری خودکار (axe) و هیچ سنجی سمی‌نمودار نیست؛ برخی فرم‌ها بدون aria/سمز. [ریسک]	ریسک انطباق و تجربه‌ی ضعیف کاربران دارای ابزار کمکی.
P1-16	SVC	نمایش موجودی SMS/وضعیت سرویس در داشبورد وجود ندارد؛ حتی با تمام‌شدن اعتبار، ادمین داخل محصول بی‌خبر است.	بحران P0-07 در لحظه‌ی بحران کشف می‌شود، نه قبلش.
P1-17	ARCH	کوئری‌های تجمیعی (count/group) برای داده‌ی بزرگ بدون precompute/ایندکس اختصاصی چک نشده‌اند. [ریسک]	رشد داده → کندی UI بدون پیش‌هشدار.
P1-18	DATA	بدون شمارش بازدید/تعامل روی محتوا (craft/tour/post/tutorial).	ادمین بدون نمایی از «سلامت محتوا»؛ ناتوان در تصمیم‌گیری/ارتقا.

۶-۴ فرعی (P2)

ID	دسته	یافته (شواهد)	اثر
P2-01	UX	ویزارد ۷ مرحله‌ای بدون autosave/draft؛ قطع اتصال → از دست رفتن ورودی.	تجربه‌ی تألیف شکننده در موبایل/اتصال ضعیف.
P2-02	UX	Toast و confirm های بحرانی (delete) یکپارچه نیستند؛ برخی action بدون تأیید. [ریسک]	حذف ناخواسته‌ی محتوا ممکن است.
P2-03	DATA	بدون ابزار مدیریت رسانه: پیش‌نمایش ضعیف، بدون جست‌وجو/فیلتر در آپلودها.	مدیریت رسانه‌ی انبوه ناخوشایند.
P2-04	DX	کنوانسیون env: بدون env.example کامل و مستند؛ SMS MOCK، SYNC_INDEXES فقط در render.yaml دیده می‌شوند.	رام‌پ/آن‌بورد مهندس جدید کند.
P2-05	TEST	تست‌های واحد UI بسیار کم؛ منطق بک‌اند خوب پوشش دارد اما بدون snapshot/PR.	سرعت بازآفرینی انتخاب‌ها پایین.
P2-06	SVC	backend/scripts/test-sms.js به dotenv وابسته است؛ در CI بدون env. محلی خطای پیکربندی می‌دهد. [ریسک]	اسکرپت دیاگرام‌گر فقط محلی کار می‌کند.
P2-07	ARCH	پنل مدیریت «یک» monolith (مدیریتی) بدون سیستم نسخه/گزارش انتشار (release notes).	ردیابی «چه تغییری کدام محیط را لمس کرد» سخت است.

۷ نقشه‌ی راه ارتقا (Roadmap) — با جزئیات اجرا

توالی بر اساس «اثر × هزینه». هر آیتم دارای: اهداف ← گام‌های پیاده‌سازی ← پشته پیشنهادی ← تلاش (روز-انسان) ← ریسک.

فاز صفر — تثبیت عملیات (هفته ۱-۲): P0-01، ۰۴، ۰۵، ۰۶، ۰۸ + P1-16

• Observability و uptime:

- گام‌ها: فعال‌سازی DSN سنتری از env؛ میان‌افزار ثبت خطای سراسری؛ متریک سبک (مدت‌زمان درخواست، نرخ خطا) در server.js؛
- غنی‌سازی /api/health با وضعیت DB + وضعیت سرویس SMS؛ اتصال (UptimeRobot/Cronitor) uptime monitor به همان health.

- پشته: Grafana/prom-client ، @sentry/node (فاز دوم)، winston در فرمت JSON.
- تلاش: ۳-۴ روز. ریسک: کم.
- **Backup خودکار Mongo:**
- گام‌ها: اسکرپت `mongodump` زمان‌بندی‌شده روی خروجی + آپلود به سرویس ذخیره‌ی نسخه‌ای (S3/Backblaze)؛ تست restore ماهانه به صورت آیتم (جلسه‌ای).
- تلاش: ۲ روز. ریسک: کم، منوط به تست بازیابی.
- **شفافیت + Resilience سرویس SMS:**
- گام‌ها: لایه‌ی (interface) `SmsProvider` → ملی‌پیامک + فراهم‌کننده‌ی دوم (مثلاً Kavenegar)؛ صف ارسال درون‌فرایند با `retry/backoff`؛ نمایش «موجودی/وضعیت» در صفحه‌ی تنظیمات ادمین؛ **پیش‌شرط: شارژ پنل** برای تست واقعی.
- تلاش: ۴ روز. ریسک: میانه (تفاوت API پنل‌ها). این مورد هم‌زمان P1-16 را می‌بندد.

فاز یک — امنیت هویت و ممیزی (هفته ۲-۴): P0-02، ۰۳، P1-01، ۰۲

- **۲FA و چرخش نشست:**
- گام‌ها: افزودن TOTP به همراه (`otplib`) OTP؛ جریان `refresh` با `revoke` + `rotate` و لیست سیاه (Redis یا Mongo با `jwt`)؛ پیاده‌سازی `logout` واقعی.
- پشته: `jose`، `otplib` یا `jsonwebtoken` با Redis، `jwt`.
- تلاش: ۴ روز. ریسک: میانه (تغییر در سرویس نشست).
- **RBAC نقش-محور:**
- گام‌ها: مدل (`super-admin`، `content-admin`، `moderator`، `city-manager`) + `Role`؛ میان‌افزار `requirePermission` روی `routes`؛ صفحه‌ی مدیریت نقش در فرانت.
- تلاش: ۶ روز. ریسک: میانه (پاکسازی گاردهای موجود).
- **Audit Log واقعی:**
- گام‌ها: (`actor`، `action`، `entity`، `before/after`، `ip`، `ts`) `audit_logs` collection؛ هوک در سرویس‌های `write`؛ صفحه‌ی مشاهده + دکمه‌ی `export` (مرتبط با P1-06).
- تلاش: ۳ روز. ریسک: کم.

فاز دو — لایه‌ی داده و BI (هفته ۴-۶): P0-05، P1-06، IV، ۱۸

- **Overview صفحه‌ی + Aggregate endpoint:**
- گام‌ها: بک‌اند با Aggregation Pipeline و `precompute` در collection جدا (`stats`)؛ `invalidate` بر روی `write` endpoint؛ (`counts`، `trends`، `top-content`) `/api/stats/overview`. فرانت: صفحه‌ی Overview با کارت KPI، انتخاب بازه (۳۰/۷/س/۲۴)، نمودار خط/بار — نیاز به افزودن کتابخانه‌ی نمودار (**Recharts**) دارد.
- تلاش: ۶-۷ روز. ریسک: میانه (حجم داده‌ی `precompute`).
- **Export و گزارش زمان‌بندی‌شده:**
- گام‌ها: endpoint استریم CSV با فیلترها؛ دکمه‌ی «خروجی» در هر جدول؛ گزارش زمان‌بندی‌شده با UI `cron` → ارسال ایمیل.
- پشته: `exceljs`، `json2csv` (در صورت نیاز اکسل)، `node-cron`.
- تلاش: ۴ روز. ریسک: کم.
- **ردیابی بازدید/تعامل:**
- گام‌ها: `event view/click/fav` در collection رأی؛ شمارنده با نمونه‌گیری؛ نمایش «بازدید» در لیست/کارت‌ها.
- تلاش: ۳ روز. ریسک: کم.

فاز سه — UX عملیاتی و بلادرنگ (هفته ۶-۸): P1-05، ۰۷، ۰۸، ۰۹، ۱۴

- **Bulk actions + ارتقای جدول:**

- گام‌ها: انتخاب چندتایی، نوار اکشن گروهی (تغییر وضعیت/حذف)، فیلترهای قابل ذخیره، مجازی‌سازی لیست بزرگ (TanStack Virtual)، confirm های یکپارچه.
- تلاش: ۵-۶ روز. ریسک: میانه.
- **بلادرنگ به‌روش SSE:**
- گام‌ها: `EventSource` برای رویدادهای write (محتوای جدید، تغییر وضعیت، اعلان)؛ ترتیب وسایل با `req.id`؛ `socket.io` فقط در صورت نیاز دوطرفه. اتصال به صفحه‌ی نقشه برای وضعیت زنده.
- تلاش: ۴ روز. ریسک: میان‌افزارها.
- **Command Palette + یکپارچه‌سازی حالت‌ها:**
- گام‌ها: میان‌بر جهشی (Ctrl+K) با جست‌وجوی محتوا/نقشه؛ الگوی واحد `skeleton/toast/error`؛ `dark mode` با `Tailwind dark`.
- تلاش: ۴ روز. ریسک: کم.
- **i18n:**
- گام‌ها: `react-i18next`؛ استخراج strings به `fa/en`؛ فونت `Vazirmatn`؛ پشتیبانی RTL/LTR.
- تلاش: ۳ روز. ریسک: کم.

فاز چهار — کیفیت، DX و زنجیره‌ی تأمین (هفته ۸-۱۰): P1-10..13, P2-05

- **پیش‌نمایش + رول‌بک + محیط production:**
 - گام‌ها: دیپلوی پیش‌نمایش per-PR روی `Render Preview`؛ اسکریپت رول‌بک به آخرین `tag`؛ `Blueprint production` (مشابه `staging` با `DSN` و `SMS` واقعی).
 - **اسکن زنجیره‌ی تأمین و گیت پوشش:**
 - گام‌ها: `npm audit --audit-level=high` در CI؛ اسکن `OSV/Trivy`؛ گیت پوشش (threshold) روی `jest/vitest`؛ تست `a11y` با `@axe-`
`core/playwright`.
 - **تست load سبک:**
 - گام‌ها: سناریوی `k6` «لیست+جزئیات» با حد `400ms < p95`.
- این فازها بر اساس فاصله‌ی فعلی طرح‌ریزی شده‌اند؛ اولویت نهایی هر فاز باید با معیارهای ROI بخش ۸ بازبینی شود.

۸) جمع‌بندی، KPI‌های پیشنهادی و معیار موفقیت

۸-۱ جمع‌بندی نهایی

- **نخشا کیفیت مهندسی پایه** خوبی دارد: امنیت سطح مبنا (`helmet/CORS/rate-limit/zod/invalid`)، تست‌های یکپارچه‌ی معنادار بک‌اند (۴۳۱)، `lint/typecheck` تمیز، فرم‌های سازمان‌یافته (ویژارد ۷ مرحله‌ای) و CI چندلایه. اینها دارایی‌هایی واقعی‌اند که پروژه‌های مشابه داخلی غالباً ندارند.
- **اما به‌عنوان «داشبورد» فاصله‌ی سیستماتیک دارد:** در هر ۹ معیار بخش ۲-۲، در ستون‌های کم‌وزن شایسته است و در دو ستون پر وزن (BI و OPS) عملاً جایگاه آخر جدول است. «نمایش داده» بدون تحلیل، و «تحلیل» بدون پایش، معنای داشبورد را محقق نمی‌کند.
- بحرانی‌ترین گلوگاه‌ها به‌ترتیب: (۱) `SMS` واقعی غیرفعال، (۲) پایش/لاگ/backup صفر، (۳) امنیت هویت تک‌لایه (`TFA/RBAC/Audit`)، (۴) صفر لایه داده.
- نقطه‌ی امیدوارکننده: بیشتر راه‌حل‌ها **افزودنی** هستند نه بازنویسی — بیانگر این است که ریشه‌های معماری (مدولار، تست‌پذیر) سالم است.

۸-۲ KPI‌های پیشنهادی (اعداد هدف برای ۶ ماه)

KPI	فعلی (برآورد)	هدف ۶ ماهه
پوشش تست بک‌اند	~ (۴۳۱ تست)	≤ ۸۰٪ با گیت CI
پوشش تست فرانت	کم	≤ ۶۰٪
MTTA خطاهای تولید (Sentry active)	∞ (نامعلوم)	> ۴ ساعت
RPO backup	تعریف نشده	≥ ۲۴ ساعت
RTO	تعریف نشده	≥ ۴ ساعت
Uptime چک شده	بدون مانیتور	≤ ۹۹.۵٪
تأخیر p95 لیست/جزئیات	ناشناخته	> ۴۰۰ms
نرخ تحویل موفق OTP	عملاً صفر	≤ ۹۸٪
ضعف‌های P0 باز	۸	•
ضعف‌های P1 باز	۱۸	≥ ۵

۸-۳ معیارهای موفقیت نسخه‌ی بعدی (Definition of Done پیشنهادی)

- ورود به داشبورد بدون ۲FA ممکن نباشد؛ هر نقش دقیقاً مجوزهای خود را داشته باشد.
- هر کنش write ادمین در `audit_logs` با قابلیت خروجی ثبت شود.
- صفحه‌ی Overview شامل ۳ کارت KPI و ≤ ۲ نمودار تعاملی با انتخاب بازه.
- هر جدول داده دارای دارای export و bulk action.
- `api/health/` وضعیت DB و SMS را گزارش کند و uptime monitor به آن وصل باشد.
- خطای production به Sentry (DSN واقعی) برسد؛ روند خطا قابل مشاهده باشد.
- CI شامل npm audit، گیت پوشش، و تست a11y باشد.

۹ پیوست

۹-۱ شواهد کلیدی (مسیرهای کد)

- پوشته‌ی فرانت: `frontend/package.json`
- پوشته‌ی بک‌اند: `backend/package.json`
- CI: `.github/workflows/ci.yml`، `.github/workflows/fe-ci.yml`
- استقرار: `render.yaml` staging:
- SMS: `backend/services/sms/melipayamakSms.js`، `backend/scripts/test-sms.js`
- کش ناقص: `backend/modules/listings/listing.geo.js:296`
- TODO دوم: `frontend/src/hooks/useProfileContent.ts:75`
- تست‌ها: `backend/__tests__/**` (۲۳ فایل)

۹-۲ روش تکرار این تحلیل

- گلات پوشه‌های فرانت/بک و استخراج dependency tree و اسکریپت‌های npm.
- ممیزی کد برای امنیت (متغیرهای env، میان‌افزارها، rate-limit، upload guard).
- فهرست صفحات و قابلیت‌های UI.
- بازبینی CI/Deploy و اسناد.
- مقایسه با مراجع بر اساس ۹ معیار وزنی.

- درجه‌بندی ضعف‌ها با ماتریس شدت/احتمال.
- تدوین roadmap با پایه‌ی فازبندی و تلاش تخمینی.

۹-۳ محدودیت‌های این نسخه از گزارش

- وب‌سورس برای به‌روزرسانی واقعی ویژگی‌های پنجره‌های مرجع در دسترس نبود (خطای 403 در ابزار جست‌وجو)؛ داده‌های مراجع بر پایه‌ی دانش ثابت تا تاریخ نگارش است.
- هیچ جلسه‌ی دسترس‌پذیری واقعی (مصاحبه با کاربر) انجام نشده؛ آیتم‌های UX با [ریسک] برآوردی‌اند.

--- پایان گزارش ---